

Clase 276 — Gobernanza de la seguridad de la información

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: (ISC)² CISSP Official Study Guide (Chapple, Stewart, Gibson) 🕒 Duración estimada: **90 min** · Nivel: **Intermedio**

Objetivo

Comprender qué es la gobernanza de seguridad de la información y en qué se diferencia de la gestión operativa. Al terminar sabrás definir una estructura de gobierno con roles claros, alinear la seguridad con los objetivos de negocio y traducir la estrategia de la dirección en políticas y apetito de riesgo. Este es el marco que da sentido a todos los controles técnicos que has aprendido en el programa.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** gobernanza de gestión y de operación en seguridad.
2. **Identificar** los roles clave (junta directiva, CISO, propietarios de datos, custodios) y sus responsabilidades.
3. **Definir** apetito, tolerancia y capacidad de riesgo de una organización.
4. **Alinear** un objetivo de seguridad con un objetivo de negocio concreto.
5. **Redactar** el borrador de una carta de gobierno (charter) de un comité de seguridad.

Temas

#	Tema	Por qué importa
1	Gobernanza vs. gestión vs. operación	Evita confundir estrategia con ejecución
2	Modelos: top-down y su necesidad	La seguridad falla si no la patrocina la dirección
3	Roles y responsabilidades (RACI)	Sin dueños, ningún control se sostiene
4	Apetito y tolerancia al riesgo	Fija el umbral de decisiones sobre riesgo
5	Alineación con el negocio	Seguridad como habilitador, no como freno
6	Due care y due diligence	Base legal de la responsabilidad de directivos
7	Comités y estructuras de reporte	Dónde se toman y escalan las decisiones

Definiciones y características

- **Gobernanza de seguridad:** conjunto de responsabilidades y prácticas ejercidas por la dirección para dar dirección estratégica, asegurar el logro de objetivos y verificar que el riesgo se gestiona.
Característica clave: es responsabilidad de la alta dirección, no del equipo técnico.

- **Apetito de riesgo (risk appetite):** cantidad de riesgo que una organización está dispuesta a aceptar para perseguir sus objetivos. *Clave:* se define arriba, guía todas las decisiones de tratamiento.
- **Tolerancia al riesgo:** la variación aceptable respecto al apetito para un riesgo concreto. *Clave:* más granular que el apetito.
- **Due care:** actuar de forma razonable y prudente para proteger los intereses de la organización. *Clave:* "hacer lo correcto".
- **Due diligence:** investigar y comprender continuamente los riesgos. *Clave:* "el proceso de asegurarse de que se hace lo correcto".
- **Propietario de datos (data owner):** responsable de clasificar la información y decidir quién accede. *Clave:* rol de negocio, indelegable.
- **Custodio de datos (data custodian):** implementa y mantiene los controles definidos por el propietario. *Clave:* rol técnico/operativo.

Herramientas y preparación

La gobernanza es una disciplina documental; las "herramientas" son plantillas y marcos. Prepara:

- Un editor de texto o Markdown para redactar el charter y la matriz RACI.
- Una hoja de cálculo (LibreOffice Calc, Excel o Google Sheets) para la matriz de roles.
- Referencias abiertas: *ISO/IEC 27014* (gobernanza de seguridad), *NIST SP 800-100* (Information Security Handbook), *COBIT 2019* de ISACA.
- Opcional: una plantilla de política del *SANS Policy Templates* (<https://www.sans.org/information-security-policy/>) para inspirarte, sin copiar.

No hay laboratorio ofensivo aquí; el trabajo es de análisis y redacción, propio de un rol de gobierno.

Laboratorio guiado (ejercicio aplicado)

Vas a construir la estructura de gobierno de seguridad de una empresa ficticia, "**Ferretería del Sur S.A.**", PYME de e-commerce con 120 empleados que procesa pagos con tarjeta.

1. **Contexto:** anota en un documento el sector, tamaño, activos críticos (plataforma web, base de datos de clientes, pasarela de pago) y las 3 amenazas que más preocupan a la dirección.
2. **Matriz RACI de roles:** en una hoja de cálculo crea filas para 6 actividades (definir política, aprobar presupuesto, clasificar datos, operar el SIEM, aprobar excepciones de riesgo, responder incidentes) y columnas para 5 roles (Junta, CEO, CISO, Propietario de datos, Equipo SOC). Marca cada celda con **Responsable**, **Aprobador**, **Consultado** o **Informado**. Regla: exactamente un **A** por fila.
3. **Apetito de riesgo:** redacta una declaración de apetito en una frase (p. ej., "aceptamos riesgo bajo en disponibilidad y riesgo muy bajo en confidencialidad de datos de pago").
4. **Objetivos alineados:** escribe una tabla de 3 filas que conecte un objetivo de negocio (crecer 30% en ventas online) con un objetivo de seguridad (disponibilidad 99,9%) y un control concreto (WAF + CDN).
5. **Charter del comité:** redacta media página con: propósito, miembros, frecuencia de reunión, decisiones que puede tomar y a quién reporta.
6. **Revisión:** verifica que ningún rol técnico aparezca como aprobador de decisiones estratégicas (eso es un error de gobierno).

Ejercicios

1. Explica con un ejemplo la diferencia entre due care y due diligence.
2. Clasifica estas tareas en gobernanza, gestión u operación: aprobar el presupuesto anual, configurar un firewall, definir el apetito de riesgo, revisar logs.
3. Diseña una matriz RACI para el proceso "gestión de parches".
4. Un directivo dice: "la seguridad es cosa del departamento de IT". Redacta una réplica de 5 líneas fundamentada en gobernanza top-down.
5. Define el apetito de riesgo para un hospital y para una startup de videojuegos; justifica por qué difieren.
6. Propón tres indicadores que un comité de seguridad debería revisar en cada reunión.

Reto verificable

Redacta el **charter completo de un comité de seguridad de la información** (máx. 1 página) para "Ferretería del Sur S.A.", con matriz RACI adjunta.

Criterio de aceptación: el charter incluye propósito, composición, cadencia, autoridad de decisión y línea de reporte a la junta; la matriz RACI tiene exactamente un aprobador por actividad y ningún rol técnico aprueba decisiones estratégicas.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"El programa de seguridad no tiene presupuesto"	Falta patrocinio de la dirección; construye caso de negocio y gobierno top-down
Nadie decide sobre excepciones de riesgo	No hay comité ni autoridad definida; crea el charter y asigna el aprobador
Controles técnicos sin dueño de negocio	Se confunde custodio con propietario; asigna propietarios de datos
Apetito de riesgo indefinido	Cada equipo decide por su cuenta; formaliza la declaración de apetito
Directivos no rinden cuentas tras un incidente	Falta due care documentado; registra decisiones y aprobaciones

Preguntas frecuentes

 **¿La gobernanza no es solo burocracia?** No: es lo que da autoridad, presupuesto y dirección a la seguridad. Sin ella, los controles técnicos carecen de respaldo y se abandonan.

 **¿Quién debe ser el CISO, técnico o gestor?** Ambos perfiles existen, pero el CISO opera en la capa de gobierno y gestión: traduce riesgo técnico a lenguaje de negocio ante la dirección.

 **¿Apetito y tolerancia son lo mismo?** No. El apetito es el nivel general que aceptas; la tolerancia es la desviación admisible para un riesgo específico.

? ¿Dónde encaja ISO 27001 en la gobernanza? ISO 27001 es el marco de gestión (SGSI); la gobernanza lo supervisa y aprueba. Lo verás en la clase 278.

Referencias

- (ISC)² CISSP Official Study Guide, dominio 1 (Security and Risk Management).
- ISO/IEC 27014:2020 — Governance of information security. <https://www.iso.org/standard/74046.html>
- NIST SP 800-100 — Information Security Handbook: A Guide for Managers. <https://csrc.nist.gov/pubs/sp/800/100>
- COBIT 2019 (ISACA). <https://www.isaca.org/resources/cobit>
- SANS Security Policy Templates. <https://www.sans.org/information-security-policy/>

Siguiente clase

Clase 277 - Gestion de riesgos: cuantitativa y cualitativa